Assessment Report

Soterion Technologies (Pty) Ltd

Assessment dates	28/08/2022 to 03/09/2022 (Please refer to Appendix for details)
Assessment Location(s)	Johannesburg (000)
Report author	Colleen Poipao
Assessment Standard(s)	ISO/IEC 27001:2013



...making excellence a habit.™

Table of contents

Executive summary 4
Changes in the organization since last assessment 6
NCR summary graphs 7
Your next steps 8
NCR close out process 8
Assessment objective, scope and criteria 9
Statutory and regulatory requirements 9
Assessment participants 10
Assessment conclusion 11
Findings from previous assessments 12
Findings from this assessment 13
Opening Meeting: 13
Top Management Interview: 13
Context of the Organization: 14
Leadership and Commitment: 15
Actions to address risks and opportunities: 16
Support: 17
Operations: 18
Operations - Annex A as per latest SoA v3.0: 20
Performance Evaluation: 25
Improvement: 26
Programme Management (SMO 3749901): 27
Next visit objectives, scope and criteria 28
Next visit plan 29
Appendix: Your certification structure & ongoing assessment programme 30
Scope of certification 30
Assessed location(s) 30
Certification assessment programme 32
Mandatory requirements – recertification 33

...making excellence a habit.™

Expected outcomes for accredited certification 34
Definitions of findings: 35
How to contact BSI 36
Notes 36
Regulatory compliance 36

Executive summary

Soterion Technologies (Pty) Ltd *(referred to as Soterion)* provides SAP Governance, Risk and Compliance (GRC) solutions to companies running SAP. Soterion's for SAP GRC solutions provide SAP clients with in-depth access risk reporting to assist in managing their access risk exposure. Established in 2011, Soterion's vision is to provide 'fit-for-purpose' value-add solutions that offer feature-rich GRC solutions to SAP companies of all shapes and sizes. Soterion for SAP has three ways to assist companies depending on their internal capability. These include:
- Soterion On-Premises: For clients looking for market leading on-premises access risk software
- Soterion Cloud: Soterion's GRC suite hosted at Soterion's DCs
- Soterion GRC as a Managed Service: For clients looking to combine 'on-tap' GRC expertise with Soterion's GRC suite

Soterion's cloud SaaS platform is a hosted offering where the Soterion's application and database resides in a Soterion datacenter (DC) on the MS Azure platform. Companies access their Soterion application using a web browser, with the option to enable MFA. This offering is well suited to companies who have a 'cloud first' strategy and/or requiring infrequent or ad-hoc access risk assessments.

Soterion's strategic direction includes:
- Growth of clients and partners around the world
- Solutions continual expansion of identified areas, as well as, expanding support of new modules that SAP adds to the SAP landscape
- Main focus remains being the world leaders in SAP GRC software and providing renowned support and consulting services

An ISO 27001:2013 REMOTE recertification assessment was conducted for Soterion, from the 29 to 31 August, using Microsoft Teams as the collaboration tool; the quality of the audio, video and screen sharing was acceptable during the sessions.

The objective of the assessment was to conduct a recertification assessment of the existing certification to ensure the elements of the proposed scope of registration and the requirements of the management standard are effectively addressed by Soterion's management system.

The ISMS scope includes the development, support and hosting processes within Soterion.
A key focus of the ISMS is to proactively identify, mitigate, monitor and manage InfoSec threats, vulnerabilities and the risks in order to protect and/or maintain the clients and company's information assets in terms of its CIA - confidentiality, integrity and availability, as well as PII privacy (POPIA/GDPR).

The recertification assessment included sessions on the Context of the Organization; Leadership Commitment; Planning; Resources; Operations (incl. Annex A); Performance Evaluation; and Improvements.

Strengths identified during the assessment sessions included:
- Highly committed Leadership who confidently presented their ISMS inputs, outputs and evidence to demonstrate conformity
- Well maintained and designed ISMS documented information to promote operational security resilience and system maturity growth
- Robust ISMS enables proactive identification of potential threats and impacts, which leads to preventative actions to improve the operational resilience against disruptive events and exposure to

...making excellence a habit.™

such events
- Soterion have already transitioned to the latest version of the ISO 27002:2022 Annex A control set. The SoA v3 dated 31 August 2022, included a mapping of the ISO 27001:2013 to the 2022 Information Security, Cybersecurity and Privacy Protection controls, as well as the inclusion of the applicable ISAE 3402 SOC II reference controls.

Future opportunities mentioned during the assessment sessions included:
- proactive succession planning and upskilling of team members
- application of GAPs identified as per the latest release of ISO 27001:2022 and ISO 27002:2022, and other ISO 27x series standards which are beneficial for the Soterion ISMS scope environment

In line with Soterion's objectives which is an enabler of their vision, mission, values and ISMS objectives, Soterion's ISMS effectively demonstrated that it is designed to support and deliver on the performance measures intended results. Therefore, the outcome of the requirements as per the assessment plan were fulfilled. For further information, please refer to the section which lists artefacts perused, interviews conducted, and observations made to demonstrate conformity or non-conformity.

The auditor found as per the evidence sampling assessed, zero (0) nonconformities and zero (0) opportunities for improvement. Based on the outcome of the assessment and the fulfilment of the remote assessment plan, Soterion is recommended for recertification of the ISO 27001:2013 Information Security Management System Standard.

I would like to thank Soterion's Leadership for their open positive approach and active participation during the assessment which enabled the process to run smoothly and to schedule.

Changes in the organization since last assessment

The following changes in relation to organization structure and key personnel involved in the certified management system were noted:

- Johan van Noordwyk is the sole director of Soterion Technologies (Pty) Ltd in South Africa, as the CEO has relocated to Mauritius

No change in relation to the audited organization's activities, products or services covered by the scope of certification was identified.

There was no change to the reference or normative documents which is related to the scope of certification.

NCR summary graphs

There have been no NCRs raised.

Your next steps

NCR close out process

Corrective actions with respect to nonconformities raised at the last assessment have been reviewed and found to be effectively implemented.

No new nonconformities were identified during the assessment. Enhanced detail relating to the overall assessment findings is contained within subsequent sections of the report.

Please refer to Assessment Conclusion and Recommendation section for the required submission and the defined timeline.

Assessment objective, scope, and criteria

The objective of the assessment was to conduct a reassessment of the existing certification to ensure the elements of the proposed scope of registration and the requirements of the management standard are effectively addressed by the organization's management system.

If this visit is part of a multi-location assessment, the final recommendation will be contingent on the findings from all assessments.

The scope of the assessment is the documented management system with relation to the requirements of ISO 27001:2013 Standard and the defined assessment plan provided in terms of locations and areas of the system and organization to be assessed.

ISO 27001:2013 Information Security Management System Standard
Soterion Information Security Management System (ISMS) documentation

Statutory and regulatory requirements

- The Compliance role is responsible to ensure the integrity, completeness, and compliance and/or conformance awareness as per the statutory, regulatory, and business requirements within Soterion's operational jurisdiction. An overview of the relevant requirements are available on the Intranet GRC --> Policies and Procedures --> Compliance Policy dated April 2022, and Contact with Authorities Information list available on this tab.
- The Compliance role is responsible to stay informed of the various statutory, regulatory, and business requirements to ensure governance oversight throughout the various business levels i.e. strategic, tactical and operations adherence to applicable requirements.

- Line of Business Leads are required to be aware of statutory, regulatory, and business requirements applicable to their operational areas and liaise accordingly with the Compliance role
- Line of Business Leads are to ensure effective compliance and/or conformance adherence, as well as to ensure awareness of relevant ISMS policies, procedures, control gates etc.. within their area of operations, thereby enabling a proactive approach to identify situations that may turn into potential violations

- Over and above BSI ISO 27001:2013 certification, Soterion have the following in place: several of the Big 5 auditing firms make use of Soterion for SAP GRC Access Control solution; SAP applications development partner; MS Partner; GDPR/POPIA adherence; ISAE 3402 conducted by Deloitte's for the period Jan-Dec 2021'; Pen testing conducted by Orange Cyberdefense for the period 24-28 Feb 2022'.

...making excellence a habit.™

Assessment participants

Name	Position	Opening meeting	Closing meeting	Interviewed (processes)
Johan van Noordwyk	Director / CISO	X	X	X

Assessment conclusion

BSI assessment team

Name	Position
Colleen Poipao	Team Leader

Assessment conclusion and recommendation

The audit objectives have been achieved and the certificate scope remains appropriate. The audit team concludes based on the results of this audit that the organization does fulfil the standards and audit criteria identified within the audit report and it is deemed that the management system continues to achieve its intended outcomes.

RECOMMENDED - The audited organization can be recommended for recertification certification to the above listed standards and has been found in general compliance with the audit criteria as stated in the above-mentioned audit plan.

Use of certification documents, mark / logo or report

The use of the BSI certification documents, and mark / logo is effectively controlled.

...making excellence a habit.™

Findings from previous assessments

Finding Reference	2123744-202110-N1	**Certificate Reference**	IS 718332
Certificate Standard	ISO/IEC 27001:2013	**Clause**	9.2
Location reference	0047743803-000		
Category	Minor		
Area/process:	9.3 Management review		
Details:	No internal audits have been conducted as per requirement of the standard		
Objective Evidence:	Internal Audit		
Cause			
Performed an internal review of the ISMS documented information as the Internal Audit Misunderstanding of the requirement			
Correction/containment			
Appointed an external competent ISO 27001 practitioner to assist with finding and ISO 27001 requirement standard know-how External party performed an Internal Audit for the 25-27 July 2022 as per the 9.2 a) and b) requirements before BSI recertification assessment 29-31 August 2022; one (1) minor non-conformance was noted which related to clause 7.4 Communications; and one (1) OFI was noted which related to clause 10.1 NCs and CAs to be tracked as per 10.1 a-g requirements			
Corrective action			
Compiled an Internal Audit schedule/plan to ensure sufficient ISMS coverage as per 9.2 a) and b) over a 3-year period			
Closed?:			
Yes			
Justification	Auditee presented the Internal Audit Report dated 25-27 July 2022 and the Internal Audit Plan and Schedule for a 3-year period		

Findings from this assessment

Opening Meeting:

An opening meeting was conducted and arrangements for the REMOTE recertification assessment was confirmed with the auditees present. Topics covered in the opening meeting included: introductions, confirmation of the visit plan, employee numbers in scope, confidentiality, BSI standard assessment approach (approach to raising nonconformities, evidential sampling, note taking, raising nonconformities, and definitions), and the ISO 27001 A11 Physical Security photos required were discussed. An opportunity for questions was presented to the parties present.

Top Management Interview:

An interview with the Director / CISO role took place covering topics such as the organizations strategic direction and priorities, future business growth, InfoSec risk concerns, objectives fulfillment and performance evaluation of the operational environment.

Soterion's strategic direction includes:
- Growth of clients and partners around the world
- Solutions continual expansion of identified areas, as well as, expanding support of new modules that SAP adds to the SAP landscape
- Main focus remains being the world leaders in SAP GRC software and providing renowned support and consulting services

The C-Suite "Top Management" acknowledge that collectively they are accountability for a suitable, adequate and effective Information Security Management System (ISMS); and as such have assigned the ISMS responsibility (5.3) to the CISO, Johan van Noordwyk, supported by the Business Unit Leads. Therefore the Top Management have, as per the standard requirement, established structures to ensure the ISMS conforms to the requirements of ISO 27001:2013 and the reporting on the ISMS performance to C-Suite in a timely manner.

The CISO demonstrated leadership and commitment (5.1) during the interview which included engagement rather than simply "committing passively", in directing Soterion's Business Units to ensure Information Assets CIA (confidentiality, integrity and availability) and P (PII privacy) levels are maintained and not compromised.

Soterion provides software and services in the SAP access risk and privacy industry, and therefore it is vital that client data is protected, especially for clients making use of Soterion's cloud offerings. It is imperative that Soterion ensures that they are impeccable custodians of the client's data, by following the best practices provided by themselves and their technology partners. The CISO further elaborate on the adherence of the ISO 27001 standard, ISAE 3402 and penetration testing to provide their clients with reputable external parties annual assessments for continued confidence relating to Soterion's service offerings and solutions.

The CISO discussed the organizations governance oversight relating to the various meetings, committees, forums etc... which took place either weekly, monthly, quarterly Management Reviews (9.3) with a cross-section of Business Unit participants. These collaborative interchanges provided for visibility of the ISMS Business Units process effectiveness and efficiency, as well as several metrics for consideration when making decisions regarding tactical and/or initiating operational actions to work towards Soterion' strategy direction and the achievement of the Information Security objectives.

Context of the Organization:

Soterion have determined and maintained their external and internal issues (4.1) and the needs and expectations of interested parties (4.2) relevant to its purpose and to the ISMS, the auditee presented the Context of the Organization available on the company Intranet i.e. available on the Intranet GRC --> About --> Context of the Organization information portal which contains topics on:
- Commercial context
- Technical context
- Strategy
- Internal and External Issues
- Interested Parties and their needs
- Scope of the ISMS
- Processes in scope a) data in motion b) data at rest
- Data to be protected a) our clients b) our company

Soterion have determined, reviewed and maintained the ISMS scope with regards to the boundaries of applicability and the interfaces and dependencies to establish their certification scope statement (4.3), which states, "The secure provision of SAP GRC software and services to hosted Soterion clients and prospects". This is according to the Statement of Applicability v3.0 dated 31 August 2022.

Soterion have determined, reviewed, and maintained their relevant documented information (7.5 – a framework of policies, processes, and procedures) required for an effective ISMS environment, these include strategical, tactical, and operational processes to ensure the fulfilment as planned to achieve the intended ISMS outcomes. The organization's ISMS repository is located on their Intranet which makes use of the collaborative MS SharePoint platform. ISMS sensitive documented information, for example C-Suite meeting minutes, strategic plans, ERM risk registers, etc... are kept in an access restricted MS SharePoint area.

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- ISMS repository is located on the Soterion's Intranet which makes use of the collaborative MS SharePoint platform. ISMS sensitive documented information, for example C-Suite meeting minutes, strategic plans, ERM risk registers, etc... are kept in a access restricted MS SharePoint area.
- Intranet Home page contains information a) Getting Started b) About c) Policies and Procedures d) Contracts and Forms e) Projects f) Risk Management and SOC controls .....
- Intranet GRC --> About --> Context of the Organization information portal which contains several topics (see above)

Leadership and Commitment:

The Leadership auditee demonstrated commitment during the assessment, which included engagement rather than simply "committing passively", in directing their Business Units in the achievement of Soterion's strategic direction, and Information Security Policy intent and direction.

As noted in the CISO interview, the C-Suite "Top Management" acknowledge that collectively they are accountability for a suitable, adequate and effective Information Security Management System (ISMS); and as such have assigned the ISMS responsibility (5.3) to the CISO, Johan van Noordwyk, supported by the Business Unit Leads. Therefore the Top Management have, as per the standard requirement, established structures to ensure the ISMS conforms to the requirements of ISO 27001:2013 and the reporting on the ISMS performance to C-Suite in a timely manner.

Soterion's C-Suite "Top Management" demonstrated their commitment through the establishment of the Information Security Policy Charter, with the purpose to achieve the highest degree of Information Assets CIA and P as per the scope definition (4.3). The Information Security Policy Charter dated April 2022, has several concise high-level statements of intent and direction as defined by the C-Suite "Top Management", evidence presented included:
- Information Security Policy Charter established is compatible with the strategic direction (5.2, 6.2)
- ensuring the integration of the Information Security Policy Charter intents and directions and other policy documents which support these statements are imbedded into the processes (4.4)
- ensuring that the resources needed for the achievement of the Information Security Policy Charter intent and direction and other policy documents which support these statements are available (5.3; 7.1)
- communicating the importance of an effective ISMS and of conforming to the requirements(7.4)
- ensuring that the Information Security Policy Charter intents and directions achieves its intended outcomes through performance evaluation i.e. process control points and defined outcomes, objectives, dashboards etc..(5.3; 9.3)
- directing and supporting persons to contribute to the effectiveness of the Information Security Policy Charter intents and directions through various communication channels and awareness activities (7.3; 7.4)
- the auditee demonstrated how the company addresses compliance with regards to statutory, regulatory and client requirements, rules, standards and codes of Good Practice, thereby ensuring a sustainable business model (5.2 c; A18.1.1)
- promoting continual improvement practice of the PDCA methodology in the processes (10.2)

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- ISMS repository is located on the Soterion's Intranet which makes use of the collaborative MS SharePoint platform
- Information Security Policy Charter dated April 2022
- Information Security Roles and Responsibilities
- Over and above BSI ISO 27001:2013 certification, Soterion has the following in place: several of the Big 5 auditing firms make use of Soterion's GRC Access Control solution; SAP applications development partner; MS Partner; GDPR/POPIA adherence; ISAE 3402 conducted by Deloitte's for the period Jan-Dec 2021'; Pen testing conducted by Orange Cyberdefense for the period 24-28 Feb 2022'
- Organization, which includes InfoSec, governance oversight is addressed in various meetings, committees, forums etc... which took place either weekly, monthly, quarterly Management Reviews (9.3) with a cross-section of Business Unit participants. These collaborative interchanges provided for visibility of the ISMS Business Units process effectiveness and efficiency, as well as several metrics for consideration when making decisions regarding tactical and/or initiating operational actions to work towards Soterion' strategy direction and the achievement of the Information Security objectives

- Intranet Getting Started page includes the following:- Information Security Acceptable Use Policy; Information Classification and Handling; Financial Information Security Policy; Remote Working Policy; Human Resources Policy; measure compliance to policies "InfoSec Checklist"; further policies relating to specific parts relating to software development / technical / legal / InfoSec incidents / Soterion's web site / ISO 27001 / GDPR etc...

Actions to address risks and opportunities:

A key focus of the ISMS regarding the ISMS (6.1.1-3) is to proactively identify, mitigate, monitor and manage InfoSec threats, vulnerabilities and the risks in order to protect and/or maintain the Information Assets in terms of their associated CIA - confidentiality, integrity and availability, as well as PII privacy (POPIA/GDPR) required levels.

Soterion have implemented, reviewed and maintained their General and InfoSec Risks. The sample of evidence presented complied to the requirements as per 6.1.1 a to e; 6.1.2 a to e; 6.1.3 a to f; which cascades into 8.2 and 8.3. It was noted during the assessment, that the ISO 27001:2013 Annex A objectives and controls sampled provided reasonable assurance that the Statement of Applicability "SoA" v3.0 dated 31 August 2022, "justified" and "not justified" were relevant; as well as been suitably designed for the Annex A objectives and controls to be achieved when operated effectively.

Soterion have already transitioned to the latest version of the ISO 27002:2022 Annex A control set. The SoA v3 dated 31 August 2022, included a mapping of the ISO 27001:2013 to the 2022 Information Security, Cybersecurity and Privacy Protection controls, as well as the inclusion of the applicable ISAE 3402 SOC II reference controls.

The Information Security Objectives (6.2) viewed on the Intranet and fulfilment status thereof in the InfoSec meeting reports; included four (4) hi-level statements, as well as, what must be done, how it must be done and how will the results be evaluated. The four (4) Information Security Objectives statements are:
- Provide a secure, always-available hosted solution to our customers
- Ensure our team is trained in information security awareness and are aware of our policies and procedures
- Compliance to information security and privacy legislation such as ISO 27001, the GDPR, POPI, etc.
- Provide our customers and staff clear plans to facilitate compliance in the case of security incidents.

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- Risk Assessment Methodology; Risk Treatment Process
- General Risk Assessment and Treatment (real-time)
- InfoSec Risk Assessment and Treatment (real-time)
- Statement of Applicability v3 dated 31 August 2022, which includes the transition to the latest version of the ISO 27002:2022 Annex A control set. The SoA v3 dated 31 August 2022, includes a mapping of the ISO 27001:2013 to the 2022 Information Security, Cybersecurity and Privacy Protection controls, as well as the inclusion of the applicable SOC reference controls
- InfoSec Objectives which include four (4) hi-level objective statements
- InfoSec Quarterly Management Report; InfoSec objectives fulfillment status include

Support:

Soterion have determined, reviewed, and maintained their Business and InfoSec internal and external resources for the establishment, implementation, maintenance, and continual improvement for an effective ISMS. The resources identified included building competence for relevant key role players (5.3; 7.1.2; 7.2), thereby ensuring an effective environment (7.1.4), adequate monitoring and measurement resources (7.1.5; 9.1), promoting organizational awareness knowledge (7.1.6; 7.3; 7.4), good standing of legal and regulatory requirements (4.2), certification body and internal auditor selection and process (9.2), and finance/budget for the necessary resources (7.1).

Soterion recognize that building and running an effective ISMS is a collaborative team approach with the relevant Business and InfoSec competence (7.2) and an understanding of the organization, its purpose and goals, its culture, risk appetite and the requirements expressed in several clauses (4.1, 4.2, 4.3, 6.1, 6.2.).

Soterion recognize that InfoSec awareness (7.3; A7.2.2) and building Business Unit knowledge base dovetails in with competence (7.2; A6.1.1) and broader communication (7.4) to all relevant interested parties. The auditees provided evidence that staff have been made aware of the:
- Information Security Policy Charter intent and direction which is supported by additional policy documents and control points imbedded within processes (4.4; 8.1; A5.1.1)
- their contribution to the effectiveness of the ISMS (6.2) - functional objectives which are cascaded down to the PDP and/or Job Role Profiles (5.3; A6.1.1) were applicable
- implications of not conforming with the ISMS requirements (10.1) - breach of procedure included in ISMS documents and part of the terms and conditions of employment (A7.1.2) and disciplinary process (A7.2.3)
- employees and contractors are required to sign NDAs (A7.2.1)
- Acceptable Use and Staff policy review surveys are performed annually to refresh InfoSec compliance (8.1; A5.1.1; A7.2.1)
- InfoSec awareness e-learning modules (7.3; A7.2.2) is performed in a measurable way (A7.2.1)

Soterion recognize that communication (7.4) requirements are a cohesive integrated part of their organization, and therefore established channels for communication which include formal C-Suite "Top Management" meetings, formal/semi-formal Business Unit and team meetings; SharePoint Business Unit portals; one-on-one touch-base meetings, team stand-up meetings as required, emails, reporting of InfoSec incidents, and several other means of engaging with the Leadership and staff.

Soterion recognize the importance of well-structured documented information required for the effectiveness of their ISMS which is reviewed to ensure relevance (A5.1.2) and easy to find, where and when it is needed (7.5.3 a). Soterion's documentation included a title description, format, review and approval for suitability and adequacy to serve its purpose (4.4). The ISMS documented information is available when required and adequately protected from loss of CIA.

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- InfoSec awareness ESET e-Learning modules which include email and web protection, social engineering, threats overview, remote workforce; InfoSec Training Register (May-June 2022) 26 colleagues completed annual training
- ISMS updates are published in the Intranet "News" section; email notifications are sent out to the relevant teams as and when important changes or updates take place in their operational area
- Organization, which includes InfoSec, governance oversight is addressed in various meetings, committees, forums etc... which took place either weekly, monthly, quarterly Management Reviews

(9.3) with a cross-section of Business Unit participants. These collaborative interchanges provided for visibility of the ISMS Business Units process effectiveness and efficiency, as well as several metrics for consideration when making decisions regarding tactical and/or initiating operational actions to work towards Soterion' strategy direction and the achievement of the Information Security objectives
- ISMS Documentation Policy, which includes:- creating and updating ISMS documents, document structure, approval and review process
- ISMS repository is located on the Soterion's Intranet which makes use of the collaborative MS SharePoint platform. ISMS sensitive documented information, for example C-Suite meeting minutes, strategic plans, ERM risk registers, etc... are kept in a access restricted MS SharePoint area.
- Intranet Home page contains information a) Getting Started b) About c) Policies and Procedures d) Contracts and Forms e) Projects f) Risk Management and SOC controls .....
- Intranet Getting Started page includes the following:- Information Security Acceptable Use Policy; Information Classification and Handling; Financial Information Security Policy; Remote Working Policy; Human Resources Policy; measure compliance to policies "InfoSec Checklist"; further policies relating to specific parts relating to software development / technical / legal / InfoSec incidents / Soterion's web site / ISO 27001 / GDPR etc...

Operations:

ISO 27001 Clause 8 requirements addressed during the assessment sessions included:
- 8.1 Operations planning and control
- 8.2 Information Security risk assessment
- 8.3 Information Security risk treatment

This section is to be read with the notes above under the heading - *Actions to address risks and opportunities.*

Soterion has considered the requirements from actions to address risks and opportunities (6.1), objectives (6.2), planning to achieve them (8.1) and control of documented information (7.5) i.e., the ISMS is well-structured and enables the achievement of operational planning and control (8.1); therefore the ISMS documented information included:
- allocation of required roles, responsibilities and authorities (5.3; A6.1.1)
- required resources are allocated and applied (7.1)
- actions required to achieve the Information Security 7 hi-level objectives (5.2, 6.2) and CIA and P risk treatments plans (8.2-3) are implemented
- suitability and effectiveness of the actions taken (4.4) to achieve the Information Security 7 hi-level objectives (6.2) are assessed and reviewed (9.1; 9.3)
- deviations from expected outcomes are corrected (10.1-2) when performance measures (6.2; 9.1; 9.2 a-b) are not achieved.
- dashboards data is collected and analyzed (9.1) as a basis for understanding the behavior of, and to demonstrate the suitability and effectiveness of the ISMS processes (8.1).

Soterion have established, reviewed and maintained their ISMS operational processes (8.1) that are necessary for service provision, including any externally provided processes/services (A15.1-2). When determining requirements for provisioning of their solutions and services, Soterion have considered both the client's statutory and regulatory requirements as well as the organizations strategic, tactical, and operational requirements (A18.1).

...making excellence a habit.™

Evidence presented by the auditees demonstrated that the ISO 27001:2013 Annex A objectives and controls necessary for the effectiveness of the ISMS - as per the InfoSec CIA and P risks identified - are treated for the intended objective outcome.

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- ISMS repository is located on the Soterion's Intranet which makes use of the collaborative MS SharePoint platform. ISMS sensitive documented information, for example C-Suite meeting minutes, strategic plans, ERM risk registers, etc... are kept in a access restricted MS SharePoint area.
* Applicable to all staff and contractors
- Information Security Policy Charter signed and dated April 2022
- Information Systems Acceptable Use Policy
- Information Classification and Handling
- Financial Information Security Policy
- ISMS Issue / Improvement Report Form
* Compliance Policies
- Privacy Policy
- User Access Management Policy
- Anti-bribery Policy
- Compliance Policy; Contract details of authorities list; InfoSec Reporting Form
* Technical Policies
- Production Server Policy
- Computer Erasure Policy
- Soterion upgrades on production environment; Minor software upgrades; Major software upgrades
* Development Policies
- Testing Strategy Policy
- Secure Development Policy
- Coding Standard Policy
- Developer Software Installation Guide
- Backup and Recovery Policy
* Support via OsTickets
- OsTickets ticketing system is in place to ensure all help desk enquiries are addressed
- Incoming tickets process, escalation, follow-up, closure etc...
- States of tickets include unassigned (default), assigned (in-progress), awaiting feedback, closed
- Support Flow Diagram
- Soterion for SAP installation guide
* HR Policies
- HR Security Policy
- Protection of PII Policy
- Harassment Policy
- Remote Working Policy
- Business Expense Policy
- Checklist employee on-boarding / Checklist employee off-boarding and Declaration of destruction of IP
- Disciplinary Process
* ..... list above is a selection of documents viewed on the Intranet

Operations - Annex A as per latest SoA v3.0:

This section is to be read with the notes above under the heading - *Operations*.

Evidence presented by the auditees demonstrated that the ISO 27001:2013 Annex A objectives and controls necessary for the effectiveness of the ISMS - as per the InfoSec CIA and P risks identified - are treated for the intended objective outcome, i.e. evidence samples provided reasonable assurance that the Annex A objectives and controls marked as "justified", are suitably designed for the control objectives to achieve effectiveness.

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- Risk Assessment Methodology; Risk Treatment Process; General Risk Assessment and Treatment (real-time); InfoSec Risk Assessment and Treatment (real-time); InfoSec Objectives which include four (4) hi-level objective statements
- Statement of Applicability v3 dated 31 August 2022, which includes the transition to the latest version of the ISO 27002:2022 Annex A control set. The SoA v3 dated 31 August 2022, includes a mapping of the ISO 27001:2013 to the 2022 Information Security, Cybersecurity and Privacy Protection controls, as well as the inclusion of the applicable SOC reference controls

A.5 Information Security Policies

A.5.1 Managing direction for InfoSec Objective: To provide management direction and support for information security in accordance with business requirements and relevant laws and regulations
A.5 Effectiveness Statement: Based on the evidence sampled, the requirements of A.5 (1x objective and 2x controls) have been addressed; a framework is in place; and controls are implemented
A.5 Evidence: Intranet artefacts mentioned in the report, relating to the ISMS repository. ISMS sensitive documented information, for example C-Suite meeting minutes, strategic plans, ERM risk registers, etc... are kept in a access restricted MS SharePoint area. The Intranet Home page contains information a) Getting Started b) About c) Policies and Procedures d) Contracts and Forms e) Projects f) Risk Management and SOC controls ..... ISMS documents are reviewed periodically (1-3 year cycle) or when significant changes take place.

A.6 Organization of Information Security

A.6.1 Internal Operations Objective: To establish a management framework to initiate and control the implementation and operation of information security within the organization
A.6.2 Mobile Devices and Teleworking Objective: To ensure the security of teleworking and use of mobile devices
A.6.Effectiveness Statement: Based on the evidence sampled, the requirements of A.6 (2x objectives and 7x controls) have been addressed; a framework is in place and controls are implemented
A.6 Evidence: Intranet artefacts mentioned in the report relating to clause Context of the Organization; Leadership and Team; InfoSec Team; Responsibilities and Contacts; InfoSec is addressed in the MS DevOps projects steps i.e. initiation to deployment to monitoring operations; Remote Working Policy; InfoSec Acceptable Use Policy ....

A.7 Human Resource Security

A.7.1 Prior to Employment Objective: To ensure that employees and contractors understand their responsibilities and are suitable for the roles for which they are considered
A.7.2 During Employment Objective: To ensure that employees and contractors are aware of and fulfil their information security responsibilities
A.7.3 Termination and Change of Employment Objective: To protect the organization's interests as part of the process of changing or terminating employment

A.7 Effectiveness Statement: Based on the evidence sampled, the requirements of A.7 (3x objectives and 6x controls) have been addressed; a framework is in place and controls are implemented
A.7 Evidence: Intranet artefacts mentioned in the report; HR documents and records are located on a restricted access SharePoint; HR Security Policy June 2022, includes the process and requirements for prior to employment screening and background checks --> T&C of employment states the employees and Soterion's responsibilities for InfoSec and data privacy --> all employees to sign over and above the T&C of employment a confidentiality and non-disclosure agreement prior to access proprietary information or processing facilities --> Management Responsibilities --> InfoSec Awareness and Training --> On-boarding and Off-boarding incl. Declaration of IP removal/destruction from laptop, delete Azure AD, remove rights, change pwd to critical services that employee had access to --> Disciplinary process --> Termination --> Segregation of duties; Remote Working Policy; InfoSec Acceptable Use Policy ....

A.8 Asset Management

A.8.1 Responsibility for Assets Objective: To identify organizational assets and define appropriate protection responsibilities
A.8.2 Information Classification Objective: To ensure that information receives an appropriate level of protection in accordance with its importance to the organization
A.8.3 Media Handling Objective: To prevent unauthorized disclosure, modification, removal, or destruction of information stored on media
A.8 Effectiveness Statement: Based on the evidence sampled, the requirements of A.8 (3x objectives and 10x controls) have been addressed; a framework is in place and controls are implemented
A.8 Evidence: Intranet artefacts mentioned in the report; Soterien make use of the MS Azure hosting platform, the MS Azure endpoint manager identifies devices (24 employees), servers, VMs etc...; Employee on-boarding / offboarding checklist; InfoSec Acceptable Use Policy; Remote Working Policy; Information Classification and Handling Policy; Computer Erasure Policy includes. data security when retiring computers and hard drives --> data sanitization; code check-in, documents on OneDrive; backup, software installed and version ...

A.9 Access Control

A.9.1 Business requirements of Access Control Objective: To limit access to information and information processing facilities.
A.9.2 User Access Management Objective: To ensure authorized user access and to prevent unauthorized access to systems and services
A.9.3 User Responsibilities Objective: To make users accountable for safeguarding their authentication information
A.9.4 System and Application Access Control Objective: To prevent unauthorized access to systems and applications
A.9 Effectiveness Statement: Based on the evidence sampled, the requirements of A.9 (4x objectives and 14x controls) have been addressed; a framework is in place and controls are implemented
A.9 Evidence viewed: Intranet artefacts mentioned in the report; User Access Management Policy June 2022 which includes access granted based on segregation of duties; MS Azure Active Directory (AAD) access management service is used for connecting authentication and authorization processes; Soterion for SAP is not a financial system and has one hosted landscape i.e. Soterion has VMs in data centers located in SA and international are connected to via VPN connections; MS Azure platform is used for client data access; no unscrambled data may leave the Azure; access to source code "Git" repositories is restricted to the development team and projects within the source code repositories are controlled based on the need-to-know principle; MS Azure environment user role assignments are reviewed quarterly by the CISO and reported on at the quarterly Exco meeting; terminated employees accounts are deactivated once notified from HR; generic user logon are monitored weekly on client databases, through a weekly review of the access logs; password policy compliance is ensured by means of the MS Azure password complexity configuration settings.

A.10 Cryptography

A.10.1 Cryptographic Controls Objective: To ensure proper and effective use of cryptography to protect the confidentiality, authenticity and/or integrity of information
A.10 Effectiveness Statement: Based on the evidence sampled, the requirements of A.10 (1x objectives and 2x controls) have been addressed; a framework is in place and controls are implemented
A.10 Evidence viewed: Intranet artefacts mentioned in the report; MS Azure managed keys are used, therefore Soterion do not manage their own keys; BitLocker drive encryption for Windows computers i.e. endpoint devices; email encryption is TLS 1.2; AES256 is used for encrypted communications and secure data storage e.g. One Drive; MS Teams uses SSTP; MS Azure VMs are encrypted; https connections make use of SSL certificates; SSL/IP Sec for VPN; electronic data in transit and at rest is encrypted with industry standard encryption methods; access to client data is managed on the MS Azure platform, no unscrambled data may leave the Azure environment; for approved testing/debugging sessions, a scrambled copy of the data may be downloaded to testing/development environments by approved Soterion employees; the use of generic user access by Soterion employees to access client databases is controlled and proactively monitored

A.11 Physical and Environmental Security

A.11.1 Secure Areas Objective: To prevent unauthorized physical access, damage and interference to the organization's information and information processing facilities
A.11.2 Equipment Objective: To prevent loss, damage, theft or compromise of assets and interruption to the organization's operations
A11 Effectiveness Statement: "Not Applicable" virtual environment
A11 Evidence viewed: "Not Applicable" virtual environment - see A.7 Human Resource Security; A.9 Access Management; A.14 System acquisition, deployment and maintenance; A.18 Compliance etc...

A.12 Operations Security

A.12.1 Operational Procedures and Responsibilities Objective: To ensure correct and secure operations of information processing facilities.
A.12.2 Protection from Malware Objective: To ensure that information and information processing facilities are protected against malware.
A.12.3 Backup Objective: To protect against loss of data.
A.12.4 Logging and Monitoring Objective: To record events and generate evidence.
A.12.5 Control of Operational Software Objective: To ensure the integrity of operational systems.
A.12.6 Technical Vulnerability Management Objective: To prevent exploitation of technical vulnerabilities.
A.12.7 Information Systems Audit Considerations Objective: To minimize the impact of audit activities on operational systems
A.12 Effectiveness Statement: Based on the evidence sampled, the requirements of A.12 (7x objectives and 14x controls) have been addressed; a framework is in place and controls are implemented
A12 Evidence viewed: Intranet artefacts mentioned in the report; Soterion uses MS Azure to provide the underlying infrastructure and components required for development, service hosting and operations; Soterion hosted environment is the platform that delivers the application to clients and is actively monitored for security threats as well as performance problems; DCs check logs for connection errors and notify the technical support team --> Soterion InfoSec team investigates and resolves; MS Azure monitors the network performance, alerts are acted on in a timely manner; InfoSec monthly meeting provides oversight of this function; stringent change control is in place i.e. only approved signoff application changes are deployed to the production servers; development/testing environments are segregated from production environments to protect from unintended changes to the application or client data; client data backups are kept in accordance with Backup and Recovery Policy June 2022 and kept in the same jurisdiction as the hosted solution; backed-up confidential data is secured with pwd

...making excellence a habit.™

and/or encryption; backups remain on the MS Azure platform; Soterion and client backups are tested regularly to ensure restoration effectiveness, this is monitored by the InfoSec team.

A.13 Communications security

A.13.1 Network Security Management Objective: To ensure the protection of information in networks and its supporting information processing facilities
A.13.2 Information Transfer Objective: To maintain the security of information transferred within an organization and with any external entity.
A13 Effectiveness Statement: Based on the evidence sampled, the requirements of A.13 (2x objectives and 7x controls) have been addressed; a framework is in place and controls are implemented
A13 Evidence viewed: Intranet artefacts mentioned in the report; MS Azure provide connectivity between DCs and internet for communication with the client's network environment; InfoSec team are responsible for ensuring that the Soterion for SAP application, operating systems and communication layers are up to date; VMs are connected via VPN connections; Soterion runs a hybrid working model therefore other than emails, applications can only be accessed through the VPN with MFA; DevOps development/testing environments are segregated from production environments to protect from unintended changes to the application or client data; Soterion for SAP is connected to SAP using SAP Router, this connection is secured using security certificates on both
sides of the connection; client data (at rest and in motion) is protected and monitored

A.14 System Acquisition, Development and Maintenance

A.14.1 Security requirements of Information Systems Objective: To ensure that information security is an integral part of information systems across the entire lifecycle. This also includes the requirements for information systems which provide services over public networks
A.14.2 Security in Development and Support Processes Objective: To ensure that information security is designed and implemented within the development lifecycle of information systems
A.14.3 Test Data Objective: To ensure the protection of data used for testing
A.14.1 Effectiveness Statement: Based on the evidence sampled, the requirements of A.14 (1x objective and 3x controls) have been addressed; a framework is in place and controls are implemented.
A.14.1 Evidence viewed: Intranet artefacts mentioned in the report; MS DevOps is used to provide an end-to-end toolchain from initiation to development which includes to quality assurance aspects to testing and deployment to production; Soterion follow a security-first development approach and GitHub flow branching strategy to expedite deployments; once application changes are approved "4-eyed principle/segregation of duties", they are deployed to the production servers; separated development/testing and production environments are in place to ensure protection against unintended changes to the application and/or client data; all application releases adhere to quality controls where development items are tested and added to release notes once testing is a GO; approved Team Leads "privilege access" have access to download scramble data for testing/debugging sessions; when performing upgrades to the production environment either the form Minor/Major software upgrades must be completed and approved "4-eyed principle/segregation of duties"; an overview of the SDLC process is described in the Secure Development Policy June 2022, as well as Development SOPs: Testing Strategy; Coding Standard; Developer Software Installation Guide; no development is outsourced (A14.2.7)

A.15 Supplier Relationships

A.15.1 Information Security in Supplier Relationships Objective: To ensure protection of the organization's assets that is accessible by suppliers
A.15.2 Supplier Service Delivery Management Objective: To maintain an agreed level of information security and service delivery in line with supplier agreements
A15 Effectiveness Statement: Based on the evidence sampled the requirements of A.15 (2x objectives and 5x controls) have been addressed; a framework is in place and controls are implemented

...making excellence a habit.™

A15 Evidence viewed: Intranet artefacts mentioned in the report; the ISMS scope is the provisioning of development, support and hosting of the Soterion for SAP solution on the MS Azure platform, therefore limited exposure with regards to supplier relationships as per the CISO; supplier due diligence took place to ensure Soterion technology partners constantly follow best practice for configuring and running hosted environments; internally the aim of ISO 27001 and ISAE 3402 is to assurance that proactive measures have been taken to ensure CIA and Privacy of Information Assets of Soterion's clients, suppliers and themselves.

A.16 Information Security Incident Management

A.16.1 Management of Information Security Incidents Management Objective: To ensure a consistent and effective approach to the management of information security incidents, including communication on security events and weaknesses
A16 Effectiveness Statement: Based on the evidence sampled, the requirements of A.16 (1x objective and 7x controls) have been addressed; a framework is in place and controls are implemented
A16 Evidence viewed: Intranet artefacts mentioned in the report; Security Incident Management Policy August 2022 defines InfoSec incidents as information disclosure to an unauthorized person, risk to information or availability, risk of data integrity; auditee demonstrated the process which included the reporting, handling, detection and identification, communication, containment, remediation, recovery, lesson learnt; no InfoSec incidents have been reported since the last BSI assessment

A.17 Information Security aspects of Business Continuity Management

A.17.1 Information Security Continuity Objective: Information security continuity shall be embedded in the organization's business continuity management systems
A.17.2 Redundancies Objective: To ensure availability of information processing facilities
A17 Effectiveness Statement: Based on the evidence sampled, the requirements of A.17 (2x objectives and 4x controls) have been addressed; a framework is in place and controls are implemented.
A17 Evidence viewed: Intranet artefacts mentioned in the report; Soterion rely on stable and constantly available information technology systems to operate, therefor to ensure such an environment, production data is backed up and resiliency is built into the MS Azure hosted production systems, the scope of the backups include production client databases, testing/demo databases, production environment, internal operation systems, testing environments; backups remain on the MS Azure platform; client data backups are kept in accordance with Backup and Recovery Policy June 2022 and kept in the same jurisdiction as the hosted solution; backed-up confidential data is secured with pwd and/or encryption; Soterion and client backups are tested regularly to ensure restoration effectiveness, this is monitored by the InfoSec team; client production databases, at least one database in the backup set from each production server must be restored and verified at least once a quarter; automated backup jobs send an email notification on completion or error to allow for easy checking by the InfoSec team; database backups are kept in a different DC in the same region; server health monitoring and rapid recovery after hardware failure is part of MS Azure's service offering, however Soterion Exco have decide to keep separate data backups to rapidly restore to alternate VMs if required; CISO reports MS Azure SLA stats as well as the backup and recovery status in the quarterly Exco meeting

A.18 Compliance

A.18.1 Compliance with Legal and Contractual Requirements Objective: To avoid breaches of legal, statutory, regulatory, or contractual obligations related to information security and of any security requirements
A.18.2 Information Security Reviews Objective: To ensure that information security is implemented and operated in accordance with the organizational policies and procedures
A18 Effectiveness Statement: Based on the evidence sampled, the requirements of A.18 (2x objectives and 8x controls) have been addressed; a framework is in place and controls are implemented.

...making excellence a habit.™

A18 Evidence viewed: Intranet artefacts mentioned in the report; Soterion operates in an environment with several regulations and legislation with which it needs to comply as articulated in the Compliance Policy April 2022; obligations include contractual agreements, for example Client SLAs; regulatory and legislative obligations for example GDPR for companies inside the EU, and POPIA for companies within South Africa; Intellectual property rights, for example SAP IDES servers, i.e. as part of our partnership with SAP, Soterion is entitled to testing systems by way of SAP IDES servers; privacy and protection of PII information to be ensured as required in relevant legislation and regulation where applicable; cryptographic regulation measures are aligned where applicable and not in violation of international or governmental intelligence regulation; InfoSec compliance to regulations and renewal of certifications (BSI ISO 27001 certification) are performed in a timely manner; InfoSec controls are subjected to an annual ISAE 3402 SOC II report; an annual penetration testing is performed by Orange Cyberdefense on the production environment to validate the hosted environments security

Performance Evaluation:

Soterion have determined, reviewed, and maintained what needs to be measured within the ISMS, how it should be measured, and how often it should be reported to ensure an effectiveness - therefore measuring of the Management System. The relevant Business Units make use of the performance indicators to evaluate the performance and effectiveness of their InfoSec areas of responsibility, identifying successes and areas requiring correction or improvement.

The annual BSI ISO 27001 assessment, Deloitte's ISAE 3402 SOC II assessment and Orange Cyberdefense penetration testing is used to identify unknown vulnerabilities i.e. the ISMS scope environment - threat and attack surface - to be proactive rather than reactive regarding Information Assets CIA and P levels been compromised.

Soterion understand the importance of a comprehensive independent Internal Audit(s) (9.2) to further enhance the ISMS effectiveness and process maturity. The Compliance role is responsible to ensure a value add approach when a) planning, implementing and maintaining a the Internal Audit program/schedule, i.e. ensure effective coverage b) defining the audit criteria and scope c) ensuring the auditors are objective and impartial d) reporting of the audits results to relevant management e) retaining documented information as evidence which is a key input to the ISO Management Review (9.3) to determine the improvement actions and needed resources. Internal Audits are important as the results provide the C-Suite and Leadership the assurance that what is meant to be happening is in fact taking place - "what you say = is what you do". The auditee presented the document Soterion Audit Plan and Schedule for a 4-year period commencing 2022-2025; and the Internal Audit Report performed on the 25 to 27 July 2022, by an external ISO 27001 practitioner, one (1) minor non-conformance was noted for clause 7.4 Communications and one (1) OFI was noted for clause 10.1-2 track and log of NCs and OFIs.

Soterion recognize the purpose of the ISO Management Review (9.3) i.e. it is the "information super highway" where the data is transformed into information "to aid factual decision making". This is where information is presented, and participants make decisions and allocate resources (5.1 c) for either ISMS changes (8.1) and/or improvements (10.2) to take place. Soterion have daily, weekly, monthly and quarterly interactions with varying cross-unit roles which address several of the input and output topics as required in 9.3. The auditee presented the minutes from the latest ISO Management Review meeting dated 11 August 2022, which addressed the required inputs and outputs as per 9.3.

The auditee presented the quarterly Exco meeting topics which included:
- review of context of the organization; General and InfoSec risk register; InfoSec objectives
- review of annual audit results if conducted since last Exco
- review of controls that are scheduled for review i.e. SoA applicable controls; SOC II controls; GDPR/POPIA controls; Soterion's additional controls; etc...
- opportunities for improvement / changes to be discussed and prioritized
- review of alert emails, InfoSec events and any major downtime events (if applicable)
- in-house compliance survey results if conducted since last Exco
- compliance report prepared by the CISO role

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- ISAE 3402 conducted by Deloitte's for the period Jan-Dec 2021'
- Penetration testing conducted by Orange Cyberdefense for the period 24-28 Feb 2022'
- General Risk Assessment and Treatment (real-time)
- InfoSec Risk Assessment and Treatment (real-time)
- InfoSec Objectives which include four (4) hi-level objective statements
- Soterion Audit Plan and Schedule for a 4-year period commencing 2022-2025; and the Internal Audit Report performed on the 25 to 27 July 2022
- Organization, which includes InfoSec, governance oversight is addressed in various meetings, committees, forums etc... which take place either weekly, monthly, quarterly Management Reviews (9.3) with a cross-section of Business Unit participants. These collaborative interchanges provided for visibility of the ISMS Business Units process effectiveness and efficiency, as well as several metrics for consideration when making decisions regarding tactical and/or initiating operational actions to work towards Soterion' strategy direction and the achievement of the Information Security objectives
- ISO Management Review meeting dated 11 August 2022
- Exco Compliance Report Q2 2022

Improvement:

Soterion recognize that nonconformities identified and the corrective actions that follow are part of the ISMS improvement cycle (10.2) and a driver to enhance process maturity. Nonconformities are mainly derived from internal and external audits, client and end-user feedback, breach or unacceptable performance of ISMS documented processes, SLA non-delivery, InfoSec (incl. Cyber) high-impact incidents etc.....

User identified improvements and nonconformities are mostly logged by emailing to the InfoSec team infosec@soterion.com or logging the issue using the ISMS Issue / Improvement Report Form. The process to be followed is described on the relevant "improvements" Intranet page. The InfoSec team assess the logged item and assign the logged issue to a responsible party who are to action and provide feedback to ensure effective tracking of the non-conformances (10.1 a-g) and improvements (10.2) from initiation to closure takes place. No items had been logged for the past 12 months at the time of the assessment.

Artefacts perused, interviews conducted, and observations made demonstrating conformity and outcome to the requirements:
- emailing of InfoSec team infosec@soterion.com or logging the issue using the ISMS Issue / Improvement Report Form; process described on the "improvements" Intranet page
- Internal Audits one (1) minor non-conformance and one (1) OFI actions taken and results thereof were included as an input in the latest ISO Management Review meeting dated 11 August 2022

Programme Management (SMO 3749901):

An off-site Program Management was carried out satisfactory, achieving objectives of preparing the assessor effectively for the certification activities. Therefore, the auditor is recommending that the recertification for the certificate **IS 718332** may go ahead as planned.

Verification of information as noted on the BSI PG and eReport system:
- SMO: 3471537+3749901; Lead C.Poipao assessment 29-31 August + reporting 3 September + PM 27 August
- Client Details: organization name, central office address location / 1x registered address for certification, contact persons, contact details
- Legal Entity: Soterion Technologies (Pty) Ltd
- Web address: https://www.soterion.com/
- Standard and scheme codes: ISO 27001:2013; T05 Telecomms & IT
- Certificate number: IS 718332
- Location reference: 0047743803-000
- Location activities: SaaS - GRC solutions for companies running SAP
- Location working model: 100% virtual model; Leadership formally meet weekly, monthly and quarterly
- FTE's within scope: 24 staff within scope
- Scope: "The secure provision of SAP GRC software and services to hosted Soterion clients and prospects, according to the Statement of Applicability Vn.n dated dd Mmmm 202y" (tbc during assessment)
- Organizations Risk Profile: * The organization's risk profile (ISO 27006:2015) and confirmation of days against UKAS requirements ISO 27001:2013 Scheme Manual - Business & IT Complexity: * Processes complexity: 1
* Type of business: 2 * Information confidentiality: 2 * IT Infrastructure complexity: 1 * Availability Requirements: 1 * Development: 1 (all in-house "SaaS)

Other Items:
- Assessment dates: BSI confirmed booking with client and type of assessment e.g. remote or on-site
- Assessment plans: Lead auditor email client (+10 working days before confirmed assessment dates) to ensure availability of relevant auditees
- Visit Plan: 3-year certification assessment cycle and sampling plan created in eReport
- Duration Calculator: completed; to be verified at the time of the assessment
- Remote assessment: client approved remote (as per PG dairy), completed auditing risk assessment
- Open & Close meeting ppt prep; eReport prep
- Client communication includes auditor confirming arrangements, proposed assessment and sampling plan, MS Team invites and other collaboration tools if remote assessment, information security / confidentiality etc....

Next visit objectives, scope, and criteria

The objective of the assessment is to conduct a surveillance assessment and look for positive evidence to verify that elements of the scope of certification and the requirements of the management standard are effectively addressed by the organization's management system; that the system is demonstrating the ability to support the achievement of statutory, regulatory and contractual requirements and the organization's specified objectives as applicable with regard to the scope of the management standard; to confirm the ongoing achievement and applicability of the forward strategic plan.

The scope of the assessment is the documented management system with relation to the requirements of ISO 27001:2022 Information Security Management System Standard and the defined assessment plan provided in terms of locations and areas of the system and organization to be assessed.

ISO 27001:2013 Information Security Management System Standard
Soterion Information Security Management System (ISMS) documentation

Please note that BSI reserves the right to apply a charge equivalent to the full daily rate for cancellation of the visit by the organization within 30 days of an agreed visit date. It is a condition of registration that a deputy management representative be nominated. It is expected that the deputy would stand in should the management representative find themselves unavailable to attend an agreed visit within 30 days of its conduct.

Next visit plan

Date	Auditor	Time	Area/process	Clause
tbc Aug 23	*tbc* C.Poipao	*tbc* 08:30-16:30	Program Management - prep for ISO 27001 assessment	n/a
			Opening Meeting	n/a
			Close-out findings from previous assessments (10.1-2)	10.1-2
			Context of the Organization (4.1-4)	4.1-4
			Planning (6.1-2)	6.1-2
			Operations (8.1-3)	8.1-3
			As per latest SoA Annex A controls - 50%	As per latest SoA Annex A controls
			Performance Evaluation (9.1-3)	9.1-3
			Improvements (10.1-2)	10.1-2
			Prep for Closing Meeting	n/a
			Closing Meeting	n/a
			eReport Writing and Administration	n/a

Appendix: Your certification structure & ongoing assessment programme

Scope of certification

IS 718332 (ISO/IEC 27001:2013)
The secure provision of SAP GRC software and services to hosted Soterion clients and prospects, according to the Statement of Applicability v3.0 dated 31 August 2022.

Assessed location(s)

The audit has been performed at Central Office.

Johannesburg / IS 718332 (ISO/IEC 27001:2013)

Location reference	**0047743803-000**
Address	Soterion Technologies (Pty) Ltd Block A, Wedgefield Office Park 17 Muswell Drive South Bryanston Johannesburg Gauteng 2021 South Africa
Visit type	Re-certification Audit (RA Opt 2)
Assessment number	3471537
Assessment dates	29/08/2022
Audit plan (revision date)	14/08/2022
Deviation from audit plan	No
Total number persons within scope of certification across ALL locations	24
Total number of persons within scope of certification at THIS location	24
Scope of activities at the site	Main certificate scope applies.
Assessment duration	3.5 day(s)

Johannesburg / IS 718332 (ISO/IEC 27001:2013)

Location reference	**0047743803-000**
Address	Soterion Technologies (Pty) Ltd Block A, Wedgefield Office Park 17 Muswell Drive South Bryanston Johannesburg Gauteng 2021 South Africa
Visit type	Programme Management
Assessment number	3749901
Assessment dates	28/08/2022
Audit plan (revision date)	14/08/2022
Deviation from audit plan	No
Total number persons within scope of certification across ALL locations	24
Total number of persons within scope of certification at THIS location	24
Scope of activities at the site	Main certificate scope applies.
Assessment duration	0.5 day(s)

Certification assessment programme

Certificate number - IS 718332
Location reference - 0047743803-000

		Audit1 Re-Cert	Audit2 CAV 1	Audit3 CAV 2	Audit4 Re-Cert
Business area/location	**Date (mm/yy):**	Aug 22	Aug 23	Aug 24	Aug 25
	Duration (days):	3.5	2	2	3.5
Program Management - prep for ISO 27001 assessment		X	X	X	X
Opening Meeting		X	X	X	X
Top Management Meeting		X			X
Close-out findings from previous assessments (10.1-2)		X	X	X	X
Context of the Organization (4.1-4)		X	X		X
Leadership (5.1-3)		X		X	X
Planning (6.1-2)		X	X	X	X
Resources (7.1-5)		X			X
Operations (8.1-3)		X	X	X	X
As per latest SoA Annex A controls - 100%		X			X
As per latest SoA Annex A controls - 50%			X	X	
Performance Evaluation (9.1-3)		X	X	X	X
Improvements (10.1-2)		X	X	X	X
Business Area(s) Xxx - InfoSec awareness, communication and application		X			X
Prep for Closing Meeting		X	X	X	X
Closing Meeting		X	X	X	X
eReport Writing and Administration		X	X	X	X

...making excellence a habit.™

Mandatory requirements – recertification

Review of assessment finding regarding conformity, effectiveness, and relevance of the management system:

In line with the Soterion's objectives which is an enabler of their vision, mission, and ISMS objectives, Soterion's ISMS effectively demonstrated that it is designed to support and deliver on the performance measures intended results. Therefore, the outcome of the requirements as per the assessment plan were fulfilled. For further information, please refer to the section which lists artefacts perused, interviews conducted, and observations made to demonstrate conformity or non-conformity.

The auditor found as per the evidence samples assessed, zero (0) minor nonconformity and zero (0) opportunities for improvement.

Management system strategy and objectives:

Soterion's strategic direction includes:
- Growth of clients and partners around the world
- Solutions continual expansion of identified areas, as well as, expanding support of new modules that SAP adds to the SAP landscape
- Main focus remains being the world leaders in SAP GRC software and providing renowned support and consulting services

The InfoSec Objectives (6.2) viewed on the Intranet and fulfilment status thereof in the InfoSec meeting reports; included four (4) hi-level statements, as well as, what must be done, how it must be done and how will the results be evaluated. The four (4) InfoSec Objectives statements are:
- Provide a secure, always-available hosted solution to our customers
- Ensure our team is trained in information security awareness and are aware of our policies and procedures
- Compliance to information security and privacy legislation such as ISO 27001, the GDPR, POPI, etc.
- Provide our customers and staff clear plans to facilitate compliance in the case of security incidents.

Next certification cycle:
Soterion have already transitioned to the latest version of the ISO 27002:2022 Annex A control set. The SoA v3 dated 31 August 2022, included a mapping of the ISO 27001:2013 to the 2022 Information Security, Cybersecurity and Privacy Protection controls, as well as the inclusion of the applicable SOC reference controls.

Therefore at the next certification cycle the client intents to be certified as per the latest release of ISO 27001:2022 and ISO 27002:2022.

Review of progress in relation to the organization's objectives:

A hi-level overview of Soterion's strategy, InfoSec Policy Charter (5.2) and InfoSec Objectives (6.2) is available on the Intranet; the InfoSec objectives fulfilment status is included as a topic in the monthly InfoSec meetings and quarterly Exco Compliance meetings.

Review of assessment progress and the recertification plan:

Business Development Manager to establish contact with Soterion's CISO to adjust the surveillance and reassessment duration based on the ISMS scope reduced ICT complexity and number of FTE's (as per initial quote). See attached Assessment Plan for clause coverage in PG.

BSI client management impartiality and surveillance strategy:

Client Manager qualifications, P T S codes are appropriate. Impartiality has been maintained, no need the change of Auditor for the reassessment and going forward over the next 3-year period in accordance with BSI processes and procedures. Multi-site consideration remains not applicable.

Do not continue with the current total assessment days/cycle.

See attached ISO 27001:2013 Audit Time Calculator in PG.

Expected outcomes for accredited certification

What accredited management system certification means?

To achieve an organization's objectives related to the Expected Outcomes intended by the management systems standard, the accredited management system certification is expected to provide confidence that the organization has a management system that conforms to the applicable requirements of the specific ISO standard.

It is to be expected that the organization

- has a system which is appropriate for its organizational context and certification scope, a defined policy appropriate for the intent of the specific management system standard and to the nature, scale and impacts of its activities, products and services over their lifecycles, is addressing risks and opportunities associated with its context and objectives;
- analyses and understands customer needs and expectations, as well as the relevant statutory and regulatory requirements related to its products, processes and services;
- ensures that product, process and service characteristics have been specified in order to meet customer and applicable statutory/regulatory requirements;
- has determined and is managing the processes needed to achieve the Expected Outcomes intended by the management system standard;
- has ensured the availability of resources necessary to support the operation and monitoring of these products, processes and services;
- monitors and controls the defined product process and service characteristics;
- aims to prevent nonconformities, and has systematic improvement processes in place including the addressing of complaints from interested parties;
- has implemented an effective internal audit and management review process;
- is monitoring, measuring, analyzing, evaluating and improving the effectiveness of its management system and has implemented processes for communicating internally, as well as responding to and communicating with interested external parties.

What accredited management systems certification does not mean?

It is important to recognize that management system standards define requirements for an organization's management system, and not the specific performance criteria that are to be achieved (such as product or service standards, environmental performance criteria etc.).

Accredited management systems certification should provide confidence in the organization's ability to meet its objectives related to the intent of the management system standard. A management systems audit is not a full legal compliance audit and does not necessarily ensure ethical behaviour or that the organization will always achieve 100% conformity and legal compliance, though this should of course be a permanent goal.

Within its scope of certification, accredited management systems certification does not imply or ensure, for example:
• that the organization is providing a superior product and service, or
• that the organization's product and service itself is certified as meeting the requirements of an ISO (or any other) standard or specification.

Definitions of findings:

Nonconformity:

Non-fulfilment of a requirement.

Major nonconformity:

Nonconformity that affects the capability of the management system to achieve the intended results. Nonconformities could be classified as major in the following circumstances:
- If there is a significant doubt that effective process control is in place, or that products or services will meet specified requirements;
- A number of minor nonconformities associated with the same requirement or issue could demonstrate a systemic failure and thus constitute a major nonconformity.

Minor nonconformity:

Nonconformity that does not affect the capability of the management system to achieve the intended results.

Opportunity for improvement:

It is a statement of fact made by an assessor during an assessment, and substantiated by objective evidence, referring to a weakness or potential deficiency in a management system which if not improved may lead to nonconformity in the future. We may provide generic information about industrial best practices, but no specific solution shall be provided as a part of an opportunity for improvement.

It is a statement of fact made by the assessor referring to a weakness or potential deficiency in a management system which, if not improved, may lead to a nonconformity in the future.

How to contact BSI

Visit the BSI Connect Portal, our web-based self-service tool to access all your BSI assessment and testing data at a time that's convenient to you. View future audit schedules, submit your corrective action plans and download your reports and Mark of Trust logos to promote your achievement. Plus, you can benchmark your performance using our dashboards to help with your continual improvement journey.

Should you wish to speak with BSI in relation to your certification, please contact your local BSI office – contact details available from the BSI website: https://www.bsigroup.com/en-GB/UK-office-locations/

Notes

This report and related documents are prepared for and only for BSI's client and for no other purpose. As such, BSI does not accept or assume any responsibility (legal or otherwise) or accept any liability for or in connection with any other purpose for which the Report may be used, or to any other person to whom the Report is shown or into whose hands it may come, and no other persons shall be entitled to rely on the Report. If you wish to distribute copies of this report external to your organization, then all pages must be included.

BSI, its staff and agents shall keep confidential all information relating to your organization and shall not disclose any such information to any third party, except that in the public domain or required by law or relevant accreditation bodies. BSI staff, agents and accreditation bodies have signed individual confidentiality undertakings and will only receive confidential information on a 'need to know' basis.

This audit was conducted through document reviews, interviews and observation of activities. The audit method used was based on sampling the organization's activities and it was aimed to evaluate the fulfilment of the audited requirements of the relevant management system standard or other normative document and confirm the conformity and effectiveness of the management system and its continued relevance and applicability for the scope of certification.

As this audit was based on a sample of the organization's activities, the findings reported do not imply to include all issues within the system.

Regulatory compliance

BSI conditions of contract for this visit require that BSI be informed of all relevant regulatory non-compliance or incidents that require notification to any regulatory authority. Acceptance of this report by the client signifies that all such issues have been disclosed as part of the assessment process and agreement that any such non-compliance or incidents occurring after this visit will be notified to the BSI client manager as soon as practical after the event.